

SECURITY_RULES.md – Tamkeen

قواعد الأمان لمنصة تمكّن

1. الهدف

ومعلومات المستخدم والبيانات المرتبطة بالمقابلات، وتقليل API تهدف قواعد الأمان في منصة تمكّن إلى حماية مفاتيح ومخاطر كشف المعلومات الحساسة أو إساءة استخدامها.

2. حماية الأسرار ومفاتيح API

- داخل الكود أو ملفات المشروع العامة API Key أو Secret عدم كشف أو مشاركة أي.
- أو ملفات الواجهة JavaScript بشكل مباشر داخل ملفات API عدم كتابة مفاتيح.
- والأسرار API لحفظ مفاتيح (Environment Variables) استخدام متغيرات البيئة.
- GitHub. أو أي ملف يحتوي على أسرار إلى .env. عدم رفع ملف.
- GitHub Repository. عدم وضع مفاتيح الخدمات أو بيانات الاعتماد داخل.

3. حماية بيانات المستخدم

- حماية معلومات المستخدم وعدم عرض البيانات الحساسة للمستخدمين غير المصرح لهم.
- عدم تخزين التسجيلات الصوتية للمقابلات إلا بعد الحصول على موافقة المستخدم.
- تقليل البيانات التي يتم جمعها أو تخزينها إلى ما تحتاجه المنصة فقط.
- عدم مشاركة بيانات المستخدم مع أي جهة غير مصرح لها.

4. التحقق من مدخلات المستخدم

- التحقق من جميع المدخلات القادمة من المستخدم قبل استخدامها.
- المدخلات لمنع إدخال محتوى ضار أو غير متوقع (Sanitize) تنظيف.
- عدم افتراض أن مدخلات المستخدم موثوقة أو آمنة.
- التحقق من نوع وقيمة البيانات، مثل الوظيفة ومستوى الخبرة وعدد الأسئلة.

5. حماية واجهة الذكاء الاصطناعي

- ضمن مدخلات المستخدم إلى نموذج الذكاء الاصطناعي API عدم إرسال أسرار أو مفاتيح.
- إرسال الحد الأدنى من بيانات المستخدم اللازمة لتقييم الإجابة.
- يحدد أن التقييم تدريبي وليس PRD عدم الاعتماد على إجابات الذكاء الاصطناعي باعتبارها حكمًا وظيفيًا حقيقيًا؛ فالـ حكمًا حقيقيًا.
- أو نتائج الذكاء الاصطناعي prompts تجنب كشف معلومات داخلية أو بيانات مستخدمين آخرين في.

6. حماية قاعدة البيانات

- حماية بيانات المقابلات والنتائج وسجل التدريب من الوصول غير المصرح به.
- Supabase أو Firebase استخدام صلاحيات وصول مناسبة عند استخدام.
- عدم تعريض بيانات قاعدة البيانات أو بيانات الاعتماد الخاصة بها في الواجهة العامة.
- عدم تخزين معلومات حساسة لا تحتاجها المنصة.

7. والنشر GitHub

- للتأكد من عدم احتوائها على مفاتيح أو أسرار GitHub مراجعة الملفات قبل رفعها إلى.

- Render عند النشر على Environment Variables استخدام.
- عدم نشر ملفات الإعدادات السرية أو بيانات الاعتماد ضمن المستودع.
- يجب إلغاؤه أو تغييره فورًا وإنشاء مفتاح جديد، API Key في حال انكشاف.

8. أمن الإجابات والتقييمات

- يجب أن يكون تقييم الإجابات مبنيًا على معايير واضحة وليس درجة عشوائية.
- يجب أن يقدم النظام ملاحظات مفهومة وقابلة للتطبيق.
- يجب ألا يختلق النظام معلومات عن الوظيفة عند إنشاء الأسئلة أو تقييم الإجابات.

9. قائمة مراجعة قبل التسليم

- داخل الكود API Keys لا توجد.
- GitHub مرفوع إلى env. لا يوجد ملف.
- Environment Variables الأسرار محفوظة باستخدام.
- مدخلات المستخدم يتم التحقق منها وتنظيفها.
- بيانات المستخدم محمية من الوصول غير المصرح به.
- التسجيلات الصوتية لا تحفظ إلا بموافقة المستخدم.
- Render تمت مراجعة إعدادات النشر على.

10. مصدر قواعد الأمان

والتي تنص على: عدم كشف الأسرار، عدم وضع Vibe Coding تم بناء قواعد الأمان الأساسية وفق متطلبات مشروع داخل الكود، التحقق من مدخلات المستخدم، تنظيف المدخلات، استخدام متغيرات البيئة، وحماية المعلومات API Keys الحساسة.